GRC & SOC Operations

Abdul Wahid

Theory, Practical Investigation & SOC L1

Q1. SOC L1 & GRC Foundations — Theory

1. Governance, Risk, and Compliance (GRC) as distinct functions

Governance is about setting the rules, responsibilities, and decision-making structure for information security. In simple words, it defines **who is responsible for what and which rules they need to follow**.

Risk management focuses on finding possible threats and weaknesses, understanding how likely they are to cause harm, and deciding how those risks should be handled.

Compliance checks whether an organization is actually following its internal policies as well as external laws, regulations, and contractual requirements.

These three areas are directly connected to the daily work of a SOC. Governance provides the security policies that the SOC has to implement. Risk assessments help the SOC decide which systems and threats need the most attention. Compliance also tells the SOC what type of logs and evidence need to be collected and retained for audits. For example, PCI-DSS may require specific log-retention practices.

---

2. NIST CSF vs. ISO/IEC 27001 vs. PCI-DSS

NIST Cybersecurity Framework (CSF) is a flexible and outcome-based framework. It is organized around **Identify, Protect, Detect, Respond, and Recover**. It is useful for organizations that want to improve or measure their cybersecurity maturity without necessarily getting a formal certification.

ISO/IEC 27001 is an internationally recognized and certifiable standard for building an **Information Security Management System (ISMS)**. It requires things such as risk management, documentation, a Statement of Applicability, controls, and continuous improvement. It would be a good choice for a company such as NexaPay that needs to demonstrate its security practices to customers, partners, or regulators.

PCI-DSS is more specific. It applies to organizations that store, process, or transmit **cardholder data**. Unlike NIST CSF, it contains detailed requirements related to areas such as network security, encryption, and vulnerability scanning.

So, in short:

- **NIST CSF:** Flexible framework for improving overall cybersecurity.
- **ISO 27001:** Formal, certifiable information-security management standard.

- **PCI-DSS:** Specific security requirements for cardholder-data environments.

The best choice depends on the organization's needs and the type of information it handles.

---

3. The Three Lines of Defense model

The **First Line of Defense** consists of operational teams that directly manage risks and perform security controls. A **SOC L1 analyst** mainly works at this level because they monitor alerts, investigate them, and take initial response actions.

The **Second Line** focuses more on risk management, compliance, and oversight. A SOC manager can have responsibilities at this level by defining detection strategies, checking whether SOC activities follow security policies, and reporting the organization's security posture.

The **Third Line** is **Internal Audit**. Internal auditors independently check whether the first and second lines are working properly. They review processes and evidence instead of carrying out the controls themselves. Their independence is important because it allows them to provide an unbiased assessment to senior management and the board.

---

4. Risk, Threat, Vulnerability, Likelihood and Impact

A **threat** is something that has the potential to cause damage. For example, an attacker trying to guess passwords is a threat.

A **vulnerability** is a weakness that an attacker can take advantage of. For example, an administrator account without MFA is a vulnerability.

Likelihood represents how probable it is that the threat will successfully exploit vulnerability.

Impact represents how serious the consequences would be if the attack succeeds.

Risk can be calculated as:

Risk = Likelihood × Impact

For example, suppose the NexaPay administrator portal does not have MFA. Credential attacks against such a portal are possible, so we can give the likelihood of a score of **4**. If

successful access would give an attacker administrative access to the payment system, the impact could be **5**.

Therefore:

Risk = 4 × 5 = 20/25

This would be considered a high-priority risk and should be addressed before a less serious issue, such as outdated firmware on a rarely used printer with a score of 4. This type of scoring helps an organization decide which risks should be fixed first when time and resources are limited.

---

5. MITRE ATT&CK in detection engineering and threat intelligence

MITRE ATT&CK provides SOC teams with a standard way of describing attacker behavior through tactics and techniques.

In **detection engineering**, analysts can map SIEM and EDR detection rules to ATT&CK techniques. This helps the SOC identify which attacker techniques it can already detect and where there are gaps.

In **threat intelligence**, analysts can take information about an attack campaign and map the attacker's TTPs to specific ATT&CK technique IDs. This makes it easier to check whether the organization has detections for those behaviors.

For example, SOC might already have good detection for **T1110 Brute Force** and **T1078 Valid Accounts** but have no detection for **T1136 Create Account** or **T1098 Account Manipulation**. If threat intelligence shows that ransomware attackers commonly use these techniques, the SOC can create new detection rules for them.

Q2. GRC Practical — Risk Assessment & Compliance Gap Analysis

Risk Register

Risk ID	Risk Description	L	I	Score	Owner	Treatment Plan
R-01	The privileged admin portal does not use MFA, increasing the chance of account compromise.	4	5	**20**	IT Security Lead	Enforce MFA for all privileged accounts within 30 days.
R-02	There is no centralized inventory of cloud assets, so cloud systems can be created without proper visibility or patch tracking.	4	4	**16**	Cloud/DevOps Lead	Deploy cloud asset discovery/CMDB and connect it with provider APIs. Enforce proper asset tagging within 60 days.
R-03	Third-party vendors with access to customer payment information do not have formal risk assessments or signed DPAs.	3	5	**15**	Vendor/Third-Party Risk Manager	Require vendor risk assessments and signed DPAs before contract renewal and complete remediation before the audit.
R-04	Encryption of cloud database data at rest has not been verified, and there is no documented key-management process.	3	5	**15**	Cloud Security Engineer / DPO	Verify encryption using the provider's KMS and document the key-management process within 45 days.
R-05	Employees are accessing internal systems from personal and unmanaged devices without MDM enrollment.	4	3	**12**	Endpoint/IT Security Lead	Enroll devices in MDM and apply conditional access within 90 days. Sensitive applications should temporarily block unmanaged devices.
R-06	The Incident Response Plan is three years old and does not properly cover the organization's cloud environment and shared responsibility requirements.	3	4	**12**	Head of Incident Response	Update the IR plan and conduct a cloud-focused tabletop exercise within 60 days.

The likelihood for **R-02 and R-05** is relatively high because shadow IT and personal-device usage are already common activities. **R-03 and R-04** have a high impact because a vendor breach or exposure of unencrypted payment information could seriously affect customers and the organization's reputation. R-06 has a lower likelihood because incidents do not happen every day, but the impact could still be significant if the response plan is outdated.

Framework Mapping

ID	Control Description	NIST CSF Function	ISO 27001 Annex A
R-01	Require MFA for privileged/admin accounts.	Protect (PR.AC-7)	A.9.4.2
R-02	Keep a centralized inventory of cloud assets/CMDB.	Identify (ID.AM-1)	A.8.1.1
R-03	Perform vendor risk assessment and obtain a signed DPA before access.	Identify (ID.SC-2)	A.15.1.1
R-04	Encrypt data at rest and document key management.	Protect (PR.DS-1)	A.10.1.1 / A.10.1.2
R-05	Enroll BYOD devices in MDM and enforce mobile-device policies.	Protect (PR.AC-3)	A.6.2.1
R-06	Update the Incident Response Plan to include cloud responsibilities.	Respond (RS.RP-1)	A.16.1.1

The Annex A references above use the **ISO/IEC 27001:2013 numbering** commonly used with NIST CSF in coursework. ISO/IEC 27001:2022 has reorganized the controls, so the edition required by the course should be used when submitting the final answer.

Policy Drafting — Access Control / MFA

Access Control Policy — Multi-Factor Authentication

All users with administrative or privileged access to core banking and payment-processing systems must use **multi-factor authentication (MFA)** whenever they log in.

MFA must use at least **two different authentication factors**, such as something the user knows, something the user possesses, or something based on the user's identity.

Privileged accounts should not normally be exempt from MFA. If a technical problem temporarily prevents MFA from being used, a suitable compensating control must be approved by the Information Security Manager. The exception and its planned resolution must also be recorded in the organization's risk register.

Compliance with this policy should be checked regularly, including during internal and external audits

Audit Impact Analysis

The issues most likely to be identified as **major non-conformities** are:

- Missing MFA for the administrative portal.
- No properly documented asset inventory.
- No formal vendor risk assessments or DPAs.
- Unverified encryption of data at rest.
- No documented key-management procedure.

These issues are important because auditors normally expect clear evidence that these controls are actually implemented. Examples of evidence could include policies, logs, signed agreements, or other records. In this case, NexaPay currently does not have enough evidence for these controls.

The **MDM/BYOD issue** and the **outdated Incident Response Plan** are also weaknesses. However, they may be treated as minor non-conformities or observations because organizations have somewhat more flexibility in how these controls are implemented.

Q3. SOC Technical Lab — Log Analysis & Detection Engineering

Evidence Identification

Brute-Force Attempt

Between **02:14:03 and 02:15:47**, there were six consecutive **Event ID 4625** failed-logon events for the svc_backup account from the same IP address, 203.0.113.45.

Several failed attempts against the same account in such a short period strongly suggest a **brute-force or password-guessing attack**.

Successful Login

At **02:16:47**, Event ID **4624** showed a successful login using **Logon Type 10**, which represents Remote Interactive/RDP access.

The account and source IP were the same as the previous failed attempts. This suggests that the attacker successfully obtained access after the password-guessing attempts.

Privileged Access

At **02:17:02**, Event ID **4672** showed that special privileges had been assigned to the new session. This indicates that the session had administrator-level or equivalent privileges.

Persistence

Between **02:18:21 and 02:21:10**, the attacker executed commands and created a new local account.

The commands included:

- net localgroup administrators /add
- whoami /all

Then Event ID **4720** showed the creation of a new account named helpdesk_tmp.

Finally, Event ID **4732** showed that this account was added to the local Administrators group.

This gave the attacker a new privileged account that could potentially be used even if the original compromised account was later secured.

Attack Timeline

Time	Event	Significance
02:14:03–02:15:47	Six Event ID 4625 failures for svc_backup from 203.0.113.45	Possible brute-force/password-guessing attack
02:16:47	Event ID 4624, Logon Type 10	Attack succeeded and RDP access was obtained
02:17:02	Event ID 4672	Session received administrator-equivalent privileges
02:18:21	Event ID 4688 — net localgroup administrators /add	Account/privilege manipulation
02:19:05	Event ID 4688 — whoami /all	Attacker checked current privileges/access
02:20:40	Event ID 4720 — helpdesk_tmp created	New account created for persistence
02:21:10	Event ID 4732 — account added to Administrators	Persistent privileged access established

---

ATT&CK Mapping

- **Credential Access — T1110 Brute Force:** Repeated Event ID 4625 failures indicate password guessing.
- **Initial Access — T1078 Valid Accounts:** The attacker successfully logged in using the legitimate svc_backup credentials.

- **Execution — T1059.003 Command and Scripting Interpreter: Windows Command Shell:** Commands such as net.exe were executed through the Windows command shell.
- **Discovery — T1033 System Owner/User Discovery:** The attacker used whoami /all to identify the current user and privileges.
- **Persistence — T1136.001 Create Account: Local Account:** The attacker created the helpdesk_tmp local account.
- **Persistence / Privilege Escalation — T1098 Account Manipulation:** The newly created account was added to the Administrators group.

Detection Improvements

I would improve the detection system in the following ways:

1. Create a rule that detects **five or more failed logins (Event ID 4625)** for the same account within a short period, such as two minutes. This should generate a high-priority alert.
2. Correlate **4625 → 4624** events. A successful login immediately after several failed attempts from the same account and source is much more suspicious than either event alone.
3. Use **UEBA** to establish normal behavior for service accounts. For example, svc_backup using RDP interactively would be unusual for a backup service account and should generate an alert.
4. Also monitor **4720 and 4732 events** involving service accounts or occurring outside normal business hours.

Q4. SOC L1 Scenario-Based Decision Making

Scenario 1 — Alert Triage Under Pressure

Investigation Order:

C → B → A → D

C — First Priority

Alert C should be investigated first because it involves a previously unseen outbound connection from a senior executive's laptop. This could indicate that the device has been compromised or that data is being sent outside the organization.

Because the system belongs to a high-value user and the activity could already be happening, it is the most urgent alert.

B — Second Priority

Alert B involves a brute-force attack against the finance-admin portal. The attempts are still failing, so there has not yet been a successful compromise. However, it is still important and can be temporarily contained by blocking the source IP or locking the affected account.

A — Third Priority

Alert A is only a single failed login on a low-value test server. By itself, it does not show a clear attack pattern, so it is less urgent.

D — Last Priority

Alert D consists of 200 alerts generated by a known and approved scheduled scanner. The main requirement is to quickly confirm that the activity matches the expected scanning schedule.

Most important information for Alert C:

I would first check whether the external destination IP has a bad reputation in threat-intelligence sources. If it is known malicious infrastructure or C2, Alert C should immediately be treated as a serious incident. If it belongs to a trusted corporate SaaS provider, the priority could be reduced.

Scenario 2 — False Positive or Escalate?

I would **close the alert as a verified false positive**, rather than simply dismissing it.

The impossible-travel alert can be explained because the user was using the organization's corporate VPN, which used an exit node in another country. The user's identity should be confirmed through a trusted method rather than by replying to the same login session that generated the alert.

Evidence I would attach to the closure:

- Raw details of both login events, including timestamps and source IPs.
- ASN and geolocation information.
- Device or user-agent information showing that both sessions came from the same device.
- Confirmation that the foreign IP belongs to the company's VPN provider.
- A record explaining how the user's identity was independently verified.
- Evidence that there was no other suspicious activity, such as unusual downloads, data access, or privilege changes.
- A timestamped analyst note explaining why the alert was closed.

Scenario 3 — Shift Handover

SHIFT HANDOVER

18:57 — M. Raza (L1 outgoing) → S. Khalid (L1 incoming)

What Happened

At **18:41**, EDR detected an obfuscated PowerShell command on workstation **ACC-WS-022**, associated with user j.tariq.

The alert was medium severity and had not been completely investigated before the end of the shift.

What Has Been Confirmed

The PowerShell process definitely executed. This is supported by the **4688 event** and the corresponding EDR process record.

The parent process was outlook.exe, so it may have started from an email attachment or link.

The PowerShell command was Base64 encoded. The first part was decoded and contained -w hidden along with a .ps1-type reference. However, the complete payload has not yet been decoded.

It is also not yet known whether the script downloaded anything or communicated with an external system.

What Still Needs Investigation

1. Finish decoding the complete Base64 PowerShell command.
2. Check proxy and firewall logs for **ACC-WS-022 between 18:38 and 18:45**.
3. Check EDR for possible logins or administrative activity from this workstation to other machines.
4. Determine whether lateral movement occurred.

What Should Be Done First?

The **proxy logs should be checked first** because they can quickly show whether the activity stayed on one computer or involved external communication.

If an unfamiliar outbound connection is discovered, the workstation should be isolated immediately and the activity treated as potentially malicious.

After that, complete the PowerShell decoding and investigate possible lateral movement.

The user has not been contacted yet. It would be better to understand what the script does first so that the analyst can ask the user relevant questions. The outgoing analyst can be contacted until around 9 PM for urgent issues.

Q5. Reflection — Integrating GRC, Technical Detection & SOC L1 Judgement

Before working on this task, I thought **GRC and SOC operations were mostly separate areas**. I saw GRC as policies, risk registers, and documentation, while SOC work seemed more focused on alerts, logs, and technical investigation.

After completing the task, I realized that they are actually closely connected. For example, the risks identified in Q2 can directly relate to the security events investigated in Q3. A brute-force attack followed by account manipulation is not just a technical incident; it can also point toward weaknesses in access control and monitoring that should be recorded and addressed as security risks.

I found **Q4, the scenario-based judgement section, the most difficult**. In the technical log analysis, the evidence is usually available in the event IDs, so with enough time you can build a clear timeline. In real SOC scenarios, however, you often have to make decisions quickly even when you do not have complete information. You have to decide which alert is most important and clearly explain your reasoning.

One of the biggest things I learned is that a SOC L1 analyst does not only need to know tools and security frameworks. They also need to understand **why an alert matters, which security control it relates to, what evidence is available, and what still needs to be investigated**.

I also learned that a good handover should clearly separate what has been **confirmed** from what is still **unknown**. This is important because the next analyst should be able to continue the investigation without making assumptions.